Lean Agentic AI for Supplier Risk Management and Performance Evaluation

Turning spreadsheet scorecards into transparent, expert-calibrated multi-agent systems: a benchmark of four approaches and an open-source demonstrator

Csaba Bakay

Working paper, draft v0.5 · October 2026

Abstract

Procurement organisations evaluate their suppliers twice: *supplier risk management* asks how exposed the company is if a supplier fails, *supplier performance evaluation* how well the supplier delivers. In practice the two are often split: a commercial risk platform is licensed for risk, while performance evaluation stays in spreadsheets, so that one supplier is judged on two inconsistent bases. Spreadsheet scorecards are transparent but cannot learn, scale or keep an audit trail; risk platforms bring data coverage and workflows at a cost, with limited control over how scores are formed, and do not cover performance evaluation. Open-source agent projects show how such systems could be built, but mostly without a defensible scoring method. Across all of them, the weights that turn criteria into a score are set once and never checked against the judgement of the people who know the suppliers. This paper makes three contributions. It proposes fifteen success factors, including the integration of risk management and performance evaluation, corrected in documented reviews. It profiles four approaches on them without aggregating them: spreadsheet practice, two commercial platforms, five open-source repositories and the approach proposed here. And it presents *Lean Agentic AI* with an open-source demonstrator whose central advantage over pure risk platforms is the integration of both views: risk management and performance evaluation on one criteria catalogue, each with its own weights, classes and actions. The demonstrator is an agentic workflow — specialised agents over a shared state, including a calibration agent and a review pause in the graph — with deterministic, material-group-specific scoring, weights calibrated against category managers' expert labels by constrained least squares, versioned weights, and concrete actions per factor. On synthetic portfolios whose labels come from a hidden weighting plus noise, calibration reduced the cross-validated error between score and label from 37.8 to 20.6 points^2, close to the irreducible label noise of 18.1, and moved the weights about half-way towards the hidden weighting. Regularisation was essential with few labels. When the simulated experts judge non-additively, apply knockouts, are uniformly stricter or disagree, calibration degrades in characteristic ways, each pointing to a design response other than calibration. The validation also exposed an acceptance rule that let harmful calibrations through; its replacement, a cross-validated rule that requires the improvement to exceed its own uncertainty, cut harmful acceptances from up to 50 % of runs to at most 4 %. The paper states what this does not establish: the labels are synthetic, predictive validity against real disruptions is untested, and the demonstrator provides only partial external signal coverage, without live monitoring. No ranking of approaches is derived at any point.

Contents

1 Introduction **2**

2 Background and related work **3**
- 2.1 Supplier risk assessment in practice 3
- 2.2 Commercial supply-chain risk platforms . . 3
- 2.3 Open-source agentic supply-chain projects . 4
- 2.4 Calibrating weights against expert judgement 4
- 2.5 Language models and determinism 4

3 Success factors **4**
- 3.1 How the factor model was derived, and corrected 4

4 Benchmark: four approaches profiled **6**
- 4.1 Method 6
- 4.2 Reading the profiles 6
- 4.3 Complementary, not ranked 6
- 4.4 Threats to validity 6

5 The Lean Agentic approach **7**
- 5.1 Definition and synthesis 7
- 5.2 Distinguishing features 7
- 5.3 What the approach is not 8

6 Architecture of the demonstrator **8**
- 6.1 Workflow 8
- 6.2 Scoring model 8
- 6.3 Weights as objects 8
- 6.4 Calibration 8
- 6.5 Human review 9
- 6.6 Two views: performance evaluation and risk management 9
- 6.7 Actions, data providers and history 9
- 6.8 Engineering properties 9

7 Demonstration on synthetic data **9**
- 7.1 Design 9
- 7.2 Reference run 10
- 7.3 Out-of-sample error and the choice of λ (E1) 10

7.4 How many labels, and how strongly to regularise (E2) . . . 10
7.5 Stability of the recovered weights (E3) . . . 11
7.6 Acceptance rules: in-sample versus cross-validated . . . 11
7.7 When experts do not judge like the model (E4) . . . 11
7.8 Requiring a clear improvement (E5) . . . 12
7.9 What the demonstration shows, and what it does not . . . 13

8 Comparison and discussion 13
8.1 What the benchmark and the demonstrator show together . . . 13
8.2 The hybrid reading: signals from outside, method in-house . . . 14
8.3 When which approach fits . . . 14
8.4 The cost of being lean . . . 14
8.5 What the "agentic" part contributes . . . 14

9 Governance and decision ownership 14

10 Limitations 15

11 Future work 16

12 Conclusion 16

Appendix A: Full comparison matrix 18

1 Introduction

Supplier risk evaluation has moved from an annual formality to a recurring management task. Disruptions in logistics, energy and geopolitics have made supply concentration visible, and supply-chain risk management research has long described identifying, assessing, treating and monitoring risk as one connected process [24, 11, 6]. This paper is concerned with the *assessment* stage. Due-diligence regulation expects documented risk analysis along the supply chain, and procurement teams are asked to show not only *which* suppliers are risky, but *why*, and what was done about it.

A common response is to extend the supplier scorecard: the criteria sheet gains columns for financial stability, supply-chain exposure and ESG, and a weighted average turns them into a score and a traffic light. Where budgets allow, a commercial platform supplies alerts and external data. Both responses leave a gap. The spreadsheet keeps the method in the procurement team's hands but does not keep a record: weights drift between versions, and no one can say afterwards why a supplier was rated as it was. The platform brings data coverage and workflows, but the method by which its score is formed is, depending on the vendor, partly or largely outside the customer's view. Open-source agent projects offer modern architecture but rarely a scoring method that would stand up in an audit.

A second gap is rarely discussed. Risk platforms address *supplier risk management*; *supplier performance evaluation* — delivery reliability, quality, price, responsiveness, graded A, B or C — is a separate, established process. A common pattern in practice is that a company licenses a risk platform and still runs its supplier evaluation in spreadsheets. The same supplier is then judged in two systems, with different criteria, scales and update cycles, and nobody sees both pictures side by side. A supplier can deliver excellently and still be a critical dependency; that is exactly the case the split hides.

One problem cuts across all three options and is rarely named: **the weights are not validated.** A scorecard may weight business impact at fourteen per cent and ESG at twelve. Those numbers usually come from a workshop, a template or a vendor default, and are seldom checked against the holistic judgement of the category managers who know the suppliers best.

This paper takes a deliberately lean route. It does not propose a new risk taxonomy or data source. It starts from the scorecard practice that already exists — for risk and for performance — and asks what it would take to evaluate both on one consistent basis and to make that practice *transparent* (method and weights documented), *reproducible* (every number recomputable), *governed* (human approval where judgement is required) and *able to learn* (weights aligned with expert judgement) — at the cost profile of open-source software. The argument proceeds in two steps: a benchmark of four approaches on fifteen success factors (Figure 1), read factor by factor without weighting, total or ranking; and an open-source demonstrator, so that each claimed property can be inspected in code, tests and documentation rather than asserted. The demonstrator runs on synthetic data. This has a cost, discussed in Section 10, and a benefit: because the labels were generated from a known hidden weighting, it can be checked whether calibration recovers it.

Contributions.

1. **Fifteen success factors** for supplier risk management and performance evaluation, including their integration, each with a definition and the evidence by which it can be assessed, together with the documented reviews that produced the current version (Section 3).
2. **A profile benchmark** of four approaches. Every value comes from one machine-readable source with a rationale and a confidence mark; the two commercial examples are rated separately (Section 4).
3. **The Lean Agentic approach**, a synthesis of scorecard practice, platform expectations and open agentic architecture. Its positioning rests on two features: the integration of risk management and performance evaluation, and calibration against expert labels inside an agentic workflow (Section 5).
4. **An open-source demonstrator**: a LangGraph workflow with deterministic scoring, material-group weights, constrained least-squares calibra-

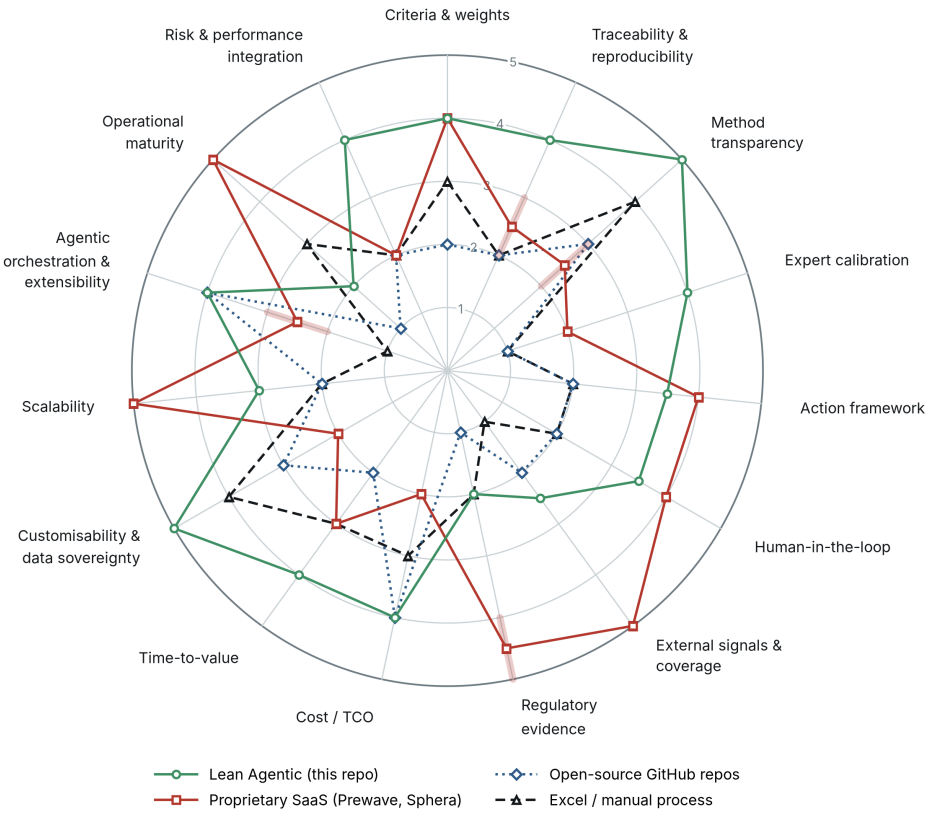


Figure 1. Four approaches to supplier risk management and performance evaluation profiled on fifteen success factors (model v0.4), on a five-level scale; half points mark a profile between two levels. Proprietary SaaS is plotted as the mean of Prewave and Sphera; shaded bars mark where the two differ. Rationale and confidence for every value: Table 10 and `research/comparison-matrix.md`. **Illustrative assessment based on public information and code review, October 2026.** The factors stay separate: no weighting is applied, no total is formed and no ranking is derived.

tion, a graph-interrupt review step, versioned weights, two views (performance evaluation and risk management), an action framework and an assessment history (Section 6), validated in five experiments (Section 7).

5. **An explicit statement of what is not established**, and of the work that would close each gap (Sections 10–11).

2 Background and related work

2.1 Supplier risk assessment in practice

Weighted multi-criteria aggregation is the dominant instrument for evaluating suppliers. Reviews of the supplier-selection literature catalogue the analytic hierarchy process, outranking, data envelopment analysis, mathematical programming and fuzzy or hybrid approaches [10, 4]; most share one structure of criteria, weights and an aggregation rule. Case studies show formal and informal supply-risk assessment processes in use, frequently in scoring form [26]. A typical supplier-risk scorecard has a *severity* component (how replaceable is the supplier, how badly would a failure hurt) and *likelihood* components for financial stability, supply-chain exposure and ESG or compliance, rated on an ordinal 1–5 scale, weighted and aggregated into a score and a class. The method is not in question here; how it is run is: definitions are informal, weights are set once, results are not reproducible after the file has changed, and consequences are free text, if they are written at all.

2.2 Commercial supply-chain risk platforms

Two platforms serve as named examples, assessed **on public information only** (vendor websites, help-centre articles, press releases, as of October 2026); nothing here is a product test. **Prewave** combines continuous media and trade-data monitoring with supplier assessments and due-diligence modules. Unusually, it publishes the composition of its supplier score: a peer component (country, industry, commodity) at 30 %, alerts at 40 %, assessments at 20 % and external data at 10 %, aggregated non-linearly. Event types and weights can be adjusted in customer-specific "perspectives"; source weighting and signal classification are not disclosed. **Sphera Supply Chain Risk Management** offers portfolio risk views, multi-tier mapping, early warnings, response playbooks and a documented bundle for the German supply-chain due-diligence act. Its scores are described as "AI-scoring" tied to business impact; no public description of the method or of customer-

adjustable weights was found.

Both use AI: Prewave for signal processing and with connectors for external AI agents, Sphera with fine-tuned generative models for supplier risk summaries and marketed "agentic AI" capabilities. Three observations matter. "Platform" is not one methodological profile: on transparency the two examples differ by a full scale point, which is why they are rated separately. **Neither documents calibration against the customer's own expert judgement**: weight adjustment exists, but as configuration, not as a fitted and reported procedure. And **both are risk platforms**: neither documents a supplier performance evaluation with its own criteria and grades, nor a customer-inspectable multi-agent workflow — specialised agents over a shared state, a calibration agent, a review pause in the workflow graph — in public sources.

2.3 Open-source agentic supply-chain projects

Five public repositories were reviewed at source-code level. They converge on one architecture — specialised agents sharing a typed state, coordinated by a graph or a supervisor — and diverge sharply on scoring. One contains no scoring at all; two compute deterministic, hard-coded weighted scores, one of them deliberately overwriting numbers produced by the language model; two leave the risk judgement to a language model, and in one a published example contains arithmetic errors in the weighted totals. Two carry no licence, one a copyleft licence, and none ships an automated test suite. The repositories are valuable as **architectural blueprints**, not as methods; this work reuses ideas from them, but no code.

2.4 Calibrating weights against expert judgement

Two practices both go by the name of "setting weights": *eliciting* them directly by asking how important each criterion is, and *inferring* them from holistic judgements of how risky each supplier is overall.

Direct elicitation is method-dependent. Different procedures (swing, SMART, trade-off, pairwise comparison) produce systematically different weights for the same problem [3, 22], and weight judgements are subject to range insensitivity and splitting biases [25]. Weights agreed in a workshop are one plausible answer among several, not a measurement.

Inferring weights has two traditions. *Judgement analysis and policy capturing*, rooted in Brunswik's lens model [8], regresses holistic judgements on cues to recover the weights a judge implicitly uses [1, 16]. Linear models reproduce such judgements well [15], and a model of a judge can outperform the judge by applying the policy consistently [7]. The tradition also cautions that "improper" weights, for example equal weights, often perform about as well as fitted ones [5]: gains from fitting should be modest, and fitted weights should not stray far from sensible priors. *Preference disaggregation* infers an additive value model from holistic evaluations, in the UTA family by linear programming on rankings [13, 14]. The calibration here belongs to the same family but fits *cardinal* scores by least squares, constrains the weights to a simplex with a lower bound, and shrinks them towards a prior. With few judgements and many weights, a fit adapts to noise; ridge regularisation trades a small bias for a large reduction in variance [12], and shrinking towards a prior instead of zero is a direct generalisation [9]. Directly elicited weights thus serve as the prior, and holistic labels adjust them under constraints.

2.5 Language models and determinism

For risk scores, language models are the wrong default. A score that changes when the same input is presented twice cannot be audited; outputs can vary across identical requests even at temperature zero, as shown for code generation [21]. A score that cannot be recomputed by hand cannot be challenged. The more mature reviewed designs compute numbers in code and reserve the language model for language. This paper adopts that division strictly.

3 Success factors

An approach is easier to assess when the properties that matter are named before any approach is rated. Table 1 proposes fifteen such *success factors*, each with the observable evidence that would let someone else check a rating. They form a **flat list**: not arranged in a hierarchy, not weighted and not combined into a total. An approach is read as a **profile**; one that is strong on twelve factors and absent on one is a different proposition from one that is uniformly adequate, and a single figure would treat the two alike.

3.1 How the factor model was derived, and corrected

The first version (v0.1) was drawn up from the requirements of the proposed approach. A critical review identified four problems, documented because they bear on how far the benchmark can be trusted. *Means presented as ends*: "open source" and "multi-agent orchestration" named the means one had chosen, which makes the comparison circular; both were reframed as outcomes (customisability and data sovereignty; extensibility). *Home-field bias*: v0.1 contained only one factor on which platforms are clearly stronger; *regulatory evidence* and *operational maturity* were added. *Overlaps*: structured criteria and objective/subjective inputs, and audit trail and determinism, were merged; transparency (understanding the method before use) was kept apart from traceability (reconstructing a result afterwards). *Validity*: no factor asks whether a score *predicts* disruptions. No reviewed approach reports predictive validity publicly, so the factor cannot be rated today; it is left off the radar and treated as an open question.

A second review (v0.3) followed practitioner feed-

Table 1. Success factors for supplier risk management and performance evaluation (model v0.4). The factors are read separately; no weighting, total or ranking is derived from them.

	Success factor	**What it means**	**Assessable by**
1	Structured criteria & weights	Explicit criteria, scales and weights combining measurable indicators and structured expert assessment	Criteria with definition and scale; explicit weights; both input types with provenance
2	Traceability & reproducibility	Every result can be reconstructed and recomputed from documented inputs	Per-result record; change history; recomputation; tests
3	Methodological transparency	The method is documented and checkable *before* use	Published formula, weights, sources, rules
4	Expert calibration	Parameters are systematically fitted to expert judgement, with approval	Procedure; fit metric; logged old and new parameters; approval
5	Action framework	Results map to defined actions, review cycles and owners	Actions per class and driver; tracking to closure
6	Human-in-the-loop & governance	Defined review and approval points, recorded decisions, roles	Approval steps; recorded overrides; roles
7	External signals & coverage	Current external data and breadth of supplier coverage	Sources, update frequency, languages, tier-N
8	Regulatory evidence	Support for due-diligence documentation duties	Regulation-specific workflows and reports
9	Cost / TCO	Total cost of use, including recurring internal effort, and access barriers	Licence model, prices, implementation effort, manual effort per cycle
10	Time-to-value	Time and effort to the first usable result	Time to first portfolio assessment
11	Customisability & data sovereignty	The organisation can change method and implementation, including material-group configuration, and controls its data	Configurable without vendor; per-group criteria, weights or thresholds; licence; data location
12	Scalability	Works as suppliers, users, groups and update frequency grow	Suppliers handled; marginal effort; automation
13	Agentic orchestration & extensibility	Work is orchestrated as an explicit workflow of specialised agents; new capabilities can be added without rebuilding the core	Specialised agents over a shared, inspectable state; review pauses in the workflow; extension points; APIs
14	Operational maturity & support	Production readiness	Support, service levels, security, release process
15	Risk & performance integration	Supplier risk and supplier performance are evaluated on one consistent basis, each with its own logic	Shared criteria and data; separate weights, classes and actions per view; both results per supplier

back (numbers in this paragraph refer to v0.3). It added factor 16, *integration of risk management and performance evaluation*, because the common split between a risk platform and spreadsheet-based evaluation was not captured by any factor. It sharpened factor 14 to *agentic orchestration and extensibility*, because "uses AI" and "is an agentic workflow" were indistinguishable; the factor stays an outcome — explicit, inspectable, extensible orchestration — but its evidence now names agents with shared state and review pauses. And it widened factor 10 to the total cost of ownership, including recurring manual effort. Factor 16 is one on which the proposed approach is strong, and factor 14 moves partly back towards an architecture property that v0.2 had reframed; both are disclosed as such. The four factors on which the commercial examples are clearly ahead (8, 9, 13 and 15) are unchanged.

A third review (v0.4) reduces the model to fifteen factors. Material-group adaptation (old 5) becomes evidence under customisability and data sovereignty (old 12, now 11): per-commodity configuration is a specific case of changing the method. Its separate axis double-counted that capability. Integration remains unchanged (old 16, now 15); old 1–4 retain their numbers and old 6–16 become 5–15. All retained scores, confidence marks and per-vendor values stay unchanged. The customisability rationales now include group configuration and its limits; the removed scores are retired, not averaged. The retained customer-control ratings are Excel 4/M, SaaS 2/M, open repos 3/H and Lean Agentic 5/H. For open repos, visible code supports modification, but neither supplies group adaptation nor removes licence constraints. Platform strengths retain their scores (now 7, 8, 12, 14).

The remaining boundaries separate structure from control, configuration from fitted calibration, method transparency from historical reconstruction, actions from approval, lifecycle cost from adoption time and capacity, customer control from workflow extension, and generic audit records from regulatory documen-

Table 2. Condensed benchmark: strongest (4–5) and weakest (1–2) factors per approach. Full matrix: Appendix, Table 10.

Approach	Strongest	Weakest
Excel / manual	Transparency; customisability	Calibration; external signals; agentic orchestration; risk & performance integration
SaaS (Prewave, Sphera)	External signals; scalability; operational maturity; regulatory evidence; action framework; human-in-the-loop	Cost; customisability; calibration; risk & performance integration
Open-source repos	Cost; agentic orchestration	Calibration; regulatory evidence; operational maturity
Lean Agentic	Transparency; customisability; risk & performance integration; calibration; agentic orchestration; traceability; cost; time-to-value	Regulatory evidence; operational maturity

tation. Governance concerns decision rights; operations concerns reliable service, infrastructure security and support. Joint risk/performance evaluation remains distinct from a structured single-view model. This is conceptual separation, not proven statistical independence: a 4×15 rating matrix has rank at most four, or three after centring. Independent validation is still needed; the full overlap review is in `research/success-factors.md`.

4 Benchmark: four approaches profiled

4.1 Method

Four approaches are rated on a five-point scale (1 weak or absent, 3 adequate, 5 very strong); a half point marks a profile clearly between two levels. Each rating carries a rationale and a confidence mark: H verified from code or primary documentation, M plausible and partly documented, L assumption. All ratings live in one machine-readable file from which Figure 1 and Table 10 are generated; a consistency check fails if the published table no longer matches the source. The evidence differs by approach, and this is disclosed (Table 2): spreadsheet practice is a stereotype based on practitioner experience; Prewave and Sphera are rated separately on public information; the five repositories by source-code review; and the demonstrator *as implemented*, not its roadmap.

4.2 Reading the profiles

Spreadsheet practice is strong where simplicity helps: it keeps formulas visible and can be changed by the team itself. It costs no licence but a great deal of recurring manual work, and a governed scorecard takes weeks to build. It is weak wherever a system property is needed — an audit trail, learning, external data, orchestration — and risk and performance usually live in separate files. Real practices vary widely, and a well-governed workbook can do better than the stereotype. **The commercial platforms are strongest on data, scale and operations**: external signals, regulatory evidence, scalability and operational maturity, with well-developed workflows. They are weaker on cost, self-determined customisation, recomputability by the customer (a design consequence of continuous monitoring rather than a flaw) and, for one of the two, transparency; their spread is largest exactly there. They are risk platforms: performance evaluation is not part of their documented scope, and their AI is not exposed as an inspectable multi-agent workflow. **The open-source repositories are blueprints**: free to license but demo-grade, with agent architectures as their main asset, and rudimentary on almost every methodological factor. **The Lean Agentic demonstrator is strongest where the method itself matters**: transparency, traceability, expert calibration and customisability (including material-group configuration) — and on the two factors that set it apart from pure risk platforms, the integration of risk management and performance evaluation and agentic orchestration (both 4, against 2 and 2.5 for the platforms). It is close to the platforms on actions and human review (3.5 against 4): the action framework and the graph-based review pause exist, but tracking to closure and roles do not. It is better than spreadsheets on cost of ownership and time-to-value, because scoring, actions and reports run automatically from a template. On external signals it reaches about half of the strongest platform (2.5 against 5): the provider interface reads open data and system exports and records their origin, while live APIs are still placeholders and there is no continuous monitoring. The architecture allows further providers, and an external-signal agent is a natural extension; this upside is not rated. The approach remains weak on regulatory evidence and operational maturity. These dips define what the approach is not.

4.3 Complementary, not ranked

The profiles do not order the approaches. Lean Agentic does not replace the data coverage of a platform. The realistic reading is **complementary**: a platform or open data serves as the *signal source*, and a transparent, calibrated model owned by procurement turns signals and internal knowledge into classes and actions (Section 8.2).

4.4 Threats to validity

Author bias: the factors and ratings come from the authors of one of the rated approaches. The v0.2 cor-

rection, rating the demonstrator as implemented, and a rationale and confidence mark for every value reduce the bias but do not remove it. The v0.3 review works in the other direction: it added a factor on which the proposed approach is strong and re-rated five factors after practitioner feedback, all of them in its favour (action framework, human-in-the-loop, time-to-value and external signals upwards; cost of spreadsheets and repositories downwards). The re-ratings are documented with their rationale and rate the implementation, not the roadmap; expected upside, for example in signal processing, is named but not rated. An independent re-rating is future work. *Public information only* for the platforms: hands-on evaluation could move several ratings. *Date dependency*: all platform ratings refer to October 2026. *Ordinal scale*: differences of one point are not measured distances.

5 The Lean Agentic approach

5.1 Definition and synthesis

Lean Agentic AI is defined here as an approach that starts from the evaluation practice an organisation already has, uses open agentic workflows as blueprints, and builds a tailored, transparent, low-cost system on top of that practice rather than replacing it. "Lean" means building only what adds value, reusing open blueprints, and keeping the method with the team that is accountable for it.

Positioning: one basis for risk and performance. The approach is not a further risk platform. Its central advantage over pure risk platforms such as Prewave and Sphera is that it evaluates *supplier risk management* and *supplier performance evaluation* on one consistent basis: one criteria catalogue, one data sheet, one engine, and two views with their own logic (Section 6.6). This closes the gap described in the introduction, where a risk platform and a spreadsheet evaluation judge the same supplier separately. It does not replace the platform's signals; it can consume them as indicators (Section 8.2). The second pillar is that the method is run by an agentic workflow whose agents — including a calibration agent — share an inspectable state and stop for human approval inside the graph.

The approach inherits from each tradition in Section 2. *From scorecard practice* it takes the domain logic: named criteria, 1–5 ratings, weighted dimensions including a severity component (availability of alternatives, change complexity, business consequence) and class-based actions. Procurement keeps its method and vocabulary; the method becomes explicit, versioned and testable. *From commercial platforms* it takes the expectations placed on a professional system: review and approval steps, an audit trail, integration of objective indicators with expert assessment, and an action framework. External signal feeds are not implemented; they are intended to come from open data or a platform, through the provider interface of Section 6.7. *From open-source agent projects* it takes the architecture — a supervisor coordinating specialised agents over a typed state — and the lesson that numbers are computed in code.

5.2 Distinguishing features

Eight features distinguish the approach; the first three carry its positioning. **(1) Integration of risk management and performance evaluation.** Each criterion is defined once, with its meaning and rating source, and shared where both views need it (for example credit risk or compliance status). Each view has its own dimensions, weights, classes, escalation rules, actions, expert labels and approvals; risk is classed low to critical, performance graded A to C. A supplier is seen in both views from the same data, and calibrating one view never changes the other. Neither commercial example documents performance evaluation as part of its platform. **(2) Calibration against expert judgement**, the central methodological contribution. Each labelled supplier receives a holistic risk score from 0 to 100 on the model's own scale, and the weights are chosen to minimise the squared error between model score and label, subject to a minimum weight per factor and weights summing to one. A ridge term pulls the solution towards the configured defaults, which protects small samples from overfitting and keeps criteria the methodology considers relevant from being switched off silently. The anchor is always the configured default, never a previous calibration, so repeated calibration on the same labels cannot drift; this problem was found by a test. Weights are applied only if the *cross-validated* error falls clearly (Sections 7.6 and 7.8), and old and new weights, errors and class agreement are reported. None of the reviewed repositories, and neither commercial example in its public documentation, offers this. **(3) Agentic orchestration.** The method runs as a graph of specialised agents — data collection, scoring, calibration, recommendation, human review — over one typed, inspectable state, coordinated by a supervisor with bounded loops. The calibration agent proposes weights; the review is a pause in the graph that resumes with a recorded decision. The commercial examples use AI for signal processing, summaries and, in one case, marketed "agentic" capabilities, but neither documents such a workflow publicly. The agents orchestrate; they do not decide (Section 8). **(4) Weights as versioned objects**: default, material-group and calibrated weights are interchangeable, never hard-coded, and every applied set is written as a new version with timestamp, approver, model version and metrics. **(5) Material-group awareness**: weights can be set and calibrated per commodity, and each supplier is scored with the most specific set available. **(6) Human-in-the-loop as a real pause**: when data is insufficient or weights are proposed, the workflow stops until a reviewer approves weights, sets a class with a comment, or defers; manual classes survive re-scoring. **(7) Determin-**

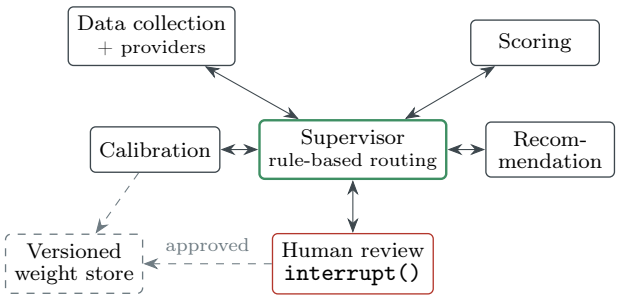


Figure 2. Workflow of the demonstrator. Every worker returns to the supervisor; calibration (with its re-score) and human review each run at most once per run. Accepted weights go to the versioned store only if auto-applied or approved.

istic scoring: every number is produced by pure, tested functions and can be recomputed by hand; language models are kept out of the numbers. **(8) Governance by construction**: escalation rules set class floors that no average can hide, a completeness check flags results resting on too little data, the audit trail is append-only, and every feedback loop is bounded.

5.3 What the approach is not

It is not a data provider (it monitors no news, disasters or tier-N networks, and ships no real external data), not a regulatory compliance product, not production-hardened (no roles, no central run store), and not empirically validated (calibration has been shown on synthetic labels only). The claim is narrower: the *method layer* of supplier risk evaluation can be made transparent, reproducible, governed and able to learn at low cost — a layer that platforms leave partly opaque and spreadsheets leave ungoverned.

6 Architecture of the demonstrator

6.1 Workflow

The demonstrator is a LangGraph state graph in hub-and-spoke form (Figure 2). A rule-based **supervisor** inspects the shared state and routes to one of five workers: *data collection* loads the suppliers in scope (optionally one material group) with indicators and expert labels, and lets optional data providers fill missing indicators; *scoring* rates factors, aggregates, normalises, classifies, applies escalation rules and checks completeness; *calibration* is optional; *recommendation* maps classes, elevated dimensions and factor levels to actions, owners and review cycles; *human review* pauses the run. Every worker returns to the supervisor, and the calibration loop and review loop each run at most once per run. The routing rules fit in one function, which is also the single extension point for a language-model-based supervisor.

6.2 Scoring model

Each factor is rated on an ordinal scale from 1 (low risk) to 5 (high risk), either by an expert or by a rule that converts a raw indicator; an expert rating always takes precedence, and the provenance of every rating is recorded. With effective factor weights θ (non-negative, summing to one), dimension ratings are weighted means of their available factors, and the overall rating R is the weighted mean of the dimensions. R is mapped to a score by min-max normalisation,

$$S = \frac{R-1}{4} \cdot 100, \tag{1}$$

so that the best possible supplier scores 0, the midpoint 50 and the worst 100; a naive $R/5$ would start at 20 and waste a fifth of the range. The mapping is affine, so rankings are unchanged and calibration stays linear. Classes follow from thresholds on S (in the template: low < 30, medium < 50, high < 70, critical from 70). Escalation rules can raise a class but never lower it. Missing factors are excluded and the remaining weights re-normalised; the share of weight backed by data is reported and, below a threshold, flagged for review.

Sub-scores. Dimension scores are reported alongside the overall score. Two combine data from different origins. **Supply chain risk** combines *political stability*, from the percentile rank of the World Bank governance indicator "Political Stability and Absence of Violence/Terrorism" [17] in bands of 20 points ($\geq 80 \to 1$, …, $< 20 \to 5$, with a generic country risk index as fallback), *sourcing strategy* (number of qualified sources) and *transport dependency* (mode and routes). **Severity** includes *change complexity*: how long it would take to move the volume to another source, including qualification, tooling and ramp-up. It can be derived from the *time to exit* in months (≤ 3, ≤ 6, ≤ 12, ≤ 24, > 24 months $\to 1, \ldots, 5$); an expert rating still takes precedence. Both mappings are ordinary rating sources with illustrative, uncalibrated bands; only weights are calibrated. The default criteria, weights and thresholds are an **illustrative template**, not a recommendation.

6.3 Weights as objects

The engine never reads weights from code. Each supplier receives the most specific available weight set: calibrated weights for its material group, configured weights for that group, calibrated global weights, or the configured defaults. Applied sets are persisted in a versioned store and loaded at the start of the next run.

6.4 Calibration

For n suppliers with complete ratings $\mathbf{x}_i$ and labels $y_i \in [0, 100]$, the calibrated weights solve

$$\begin{aligned} \min_{\theta} \; & \frac{1}{n} \sum_i \left(\frac{s_i(\theta) - y_i}{100} \right)^2 + \lambda \, \|\theta - \theta_{\text{anchor}}\|^2 \\ \text{s.t.} \quad & \theta_f \geq w_{\min} \;\; \forall f, \qquad \textstyle\sum_f \theta_f = 1, \end{aligned} \tag{2}$$

with $s_i(\theta) = (\mathbf{x}_i \cdot \theta - 1)/4 \cdot 100$ and θ_{anchor} the configured defaults. This is a convex quadratic program,

least squares with linear constraints [19], solved by sequential least squares with an analytic gradient. Defaults: $\lambda = 0.05 \times 32/n$ (Section 7.4), $w_{\min} = 0.02$, at least eight labels with complete data, and acceptance only if the cross-validated error falls by at least 5 % (5 folds × 3 repeats) *and* by at least two standard errors ($z \geq 2$; Section 7.8). Only complete suppliers are used, since missing-data re-weighting would make the score non-linear in θ. The report also checks for a **level offset** between labels and scores, which weights cannot express (Section 7.7); a flagged offset withholds the calibration for review. Labels are expected as scores rather than classes, which carry less information and would make the fit non-linear; class agreement is reported alongside the error.

6.5 Human review

The review step uses the graph framework's interrupt mechanism. The run is checkpointed, and a structured request lists flagged suppliers with reasons and any proposed weights with their metrics. The run resumes with a decision object: approved weights are stored with the reviewer's name and the portfolio is re-scored; manual classes survive re-scoring and are marked as overrides; recommendations are rebuilt after any change; invalid decisions are reported and ignored.

6.6 Two views: performance evaluation and risk management

Practice distinguishes two questions about the same supplier. **Performance evaluation** looks back — how well does the supplier deliver? — at delivery reliability, quality, price and responsiveness, and grades suppliers A, B or C. **Risk management** looks forward — how exposed are we if the supplier fails? — at replaceability, financial stability, supply-chain structure and compliance. The answers can diverge: in the sample portfolio, two suppliers are critical in the risk view and A in the performance view. The demonstrator therefore keeps both as separate **views** on one engine; this integration is the approach's central advantage over pure risk platforms (Section 5). Each criterion, with its meaning and rating source, is defined once in a shared catalogue, and criteria such as credit risk or compliance status serve both views. Each view has its own configuration of criteria, dimensions, weights, classes, escalation rules and actions. Internally every view computes 0 = favourable … 100 = unfavourable; the performance view is only *displayed* as higher-is-better. Expert labels, weight versions, runs and reviews are kept per view, so calibrating one view never changes the other. Everything in this section applies to each view; the experiments in Section 7 use the risk view, and calibration of the performance view is switched off in the template.

6.7 Actions, data providers and history

Action framework. Recommendations come from three levels, all configured per view: per class with a review cycle; per elevated dimension score; and per factor and level with a typical owner, where the most specific level reached applies. For example, availability of alternatives rated 4 leads to a market scan, rated 5 to qualifying an alternative source. The actions of a portfolio form an exportable action plan; tracking to closure is not implemented. **Data providers.** A slim interface fills indicators missing from the supplier data and records the origin and vintage of each value. Hand-entered values are never overwritten, and a failing provider is reported without stopping the assessment. Bundled are a political stability provider reading a user-downloaded table (a fictional table, marked as such, serves the sample data), a generic provider for tabular exports from ERP, ESG-platform or credit-agency systems, and documented placeholders for API integrations. Providers deliver indicators only; rating stays with the rating sources, so the method does not change when a source does. **History.** Assessments can be recorded as timestamped snapshots per view, explicitly or automatically after an approved review, with scores, classes, dimension scores, weights and approver, so that suppliers and material groups can be followed over time. Scores can be recomputed at any time; snapshots are therefore not taken on every recalculation, which would only add noise. **Spreadsheet surface.** A browser interface presents all of this as a sheet, with dashboards per material group, the action plan and the history; all numbers come from the package.

6.8 Engineering properties

The demonstrator ships with 121 automated tests covering scoring and weights in both views, calibration (including recovery of known weights from noise-free labels), the weight store and review flow, rating sources, providers, actions, reporting, history, the interface, the consistency of the benchmark data and the reproducibility of the synthetic datasets. Continuous integration runs linting and tests on two Python versions; the checkpointer restores only allow-listed state types. The code is MIT-licensed; all data is fictional or synthetic and labelled as such.

7 Demonstration on synthetic data

All numbers in this section are produced by deterministic scripts in the repository, run on commit `6bb05b9` and re-checked on `c9a500f`; the tables behind every figure are in `docs/paper/results/`.

7.1 Design

Generator. Synthetic suppliers are drawn with random ratings and indicators. Each receives an "expert label": its score under a **hidden weighting**, plus Gaussian noise ($\sigma = 4$), rounded to steps of five as category managers tend to state judgements, and clipped to $[0, 100]$. The hidden weighting differs from the template: the simulated experts care more about business impact (22 % instead of 14 %) and single sourcing

Table 3. E1: repeated 5-fold cross-validation on the reference portfolio (32 labels, 20 repeats). MSE in points^2; noise floor 18.1; default weights: 37.8 out of fold and 84 % out-of-fold class agreement. ±: standard deviation across repeats. *Synthetic data.*

λ	CV MSE	in-sample	class agr.	L1 to hidden
0	22.9 ± 4.2	10.0	81 %	0.155
0.02	20.8 ± 2.7	10.7	83 %	0.142
0.05	$\mathbf{20.6 \pm 2.0}$	12.4	86 %	0.163
0.2	24.4 ± 1.2	18.9	84 %	0.241
1	32.3 ± 0.5	29.9	84 %	0.309
5	36.4 ± 0.1	35.8	84 %	0.337

(16 % instead of 8.75 %) and less about the ESG rating (3 % instead of 12 %). Noise and rounding imply an **irreducible error of 18.1 points^2** (noise floor) that no model can beat out of sample. Because the generating weights are known, calibration can be judged on whether it reduces error out of sample, whether it moves the weights towards the truth, and how both depend on λ and n. **Data.** A reference portfolio of 36 suppliers (32 labelled), shipped with the repository; training draws of 8–192 labels (30 seeds per size, plus 100 seeds at $n = 32$); and an independent test set of 2,000 suppliers, scored also against noise-free true scores to isolate estimation error. **Experiments.** E1: repeated 5-fold cross-validation [23, 18] on the reference portfolio over λ; E2: sample size $\times$ λ on the test set; E3: weight stability over 100 seeds; E4: misspecified expert policies; E5: the acceptance threshold.

7.2 Reference run

On the reference portfolio with $\lambda = 0.05$, the error between score and label falls from 37.8 to 13.3 points^2, class agreement rises from 84 % to 88 %, the L1 distance to the hidden weighting falls from 0.345 to 0.138, and 2 of 36 suppliers change class. The acceptance rule accepts the calibration on an out-of-fold error of 37.8 → 22.8 ($z = 2.4$). The in-sample 13.3 lies *below* the noise floor: ten weights fitted to 32 noisy labels partly fit the noise. E1 quantifies by how much.

7.3 Out-of-sample error and the choice of λ (E1)

Calibration generalises (Table 3, Figure 3): at $\lambda = 0.05$ the cross-validated error falls from 37.8 to 20.6, a 45 % reduction within 2.5 points^2 of the noise floor, while the in-sample error overstates the gain by about 8 points^2. The default lies at the bottom of the curve, but it was set before this experiment on data from the same generator, so this is consistency, not proof. Regularisation buys stability more than accuracy: from $\lambda = 0$ to 0.05 the mean improves modestly and its spread halves; strong regularisation gives up most of the gain. Error and class agreement can diverge: without regularisation, out-of-fold class agreement *falls* below the default (81 % vs. 84 %) although the error improves — which is why both are reported.

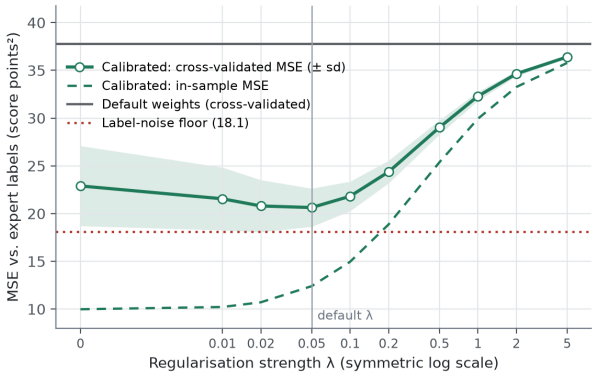


Figure 3. Cross-validated and in-sample MSE of calibrated weights versus λ on the reference portfolio. Horizontal lines: cross-validated error of the default weights and the irreducible label noise. The gap between the solid and dashed lines is the in-sample optimism. *Synthetic data.*

Table 4. E2: test error against true scores (mean over 30 seeds; default weights 29.7) and, in brackets, the share of seeds in which calibration beats the defaults. Fixed λ, the scaled default $0.05 \times 32/n$, and λ chosen by cross-validation with the minimum-error rule. *Synthetic data.*

n	$\lambda = 0$	$\lambda = 0.05$	**scaled**	CV min
8	37.7 (50 %)	16.7 (90 %)	**18.4 (100 %)**	24.5 (90 %)
16	16.2 (90 %)	9.9 (100 %)	**11.5 (100 %)**	12.8 (100 %)
32	6.1 (100 %)	5.9 (100 %)	**5.9 (100 %)**	5.6 (100 %)
64	2.8 (100 %)	4.2 (100 %)	**3.0 (100 %)**	3.0 (100 %)
192	0.8 (100 %)	2.5 (100 %)	**0.8 (100 %)**	0.8 (100 %)

7.4 How many labels, and how strongly to regularise (E2)

Against the noise-free true scores, the default weights have a structural error of 29.7 points^2 (Table 4, Figure 4).

Small samples need regularisation. With eight labels and no regularisation, calibration is *worse* than the defaults on average (37.7 vs. 29.7) and wins in only half of the seeds; with $\lambda = 0.05$ the same labels nearly halve the error and win in 90 %. At 32 labels the default removes about 80 % of the structural error (29.7 → 5.9). **A fixed λ becomes a bias at large** n: beyond about 48 labels the unregularised fit is better (0.8 vs. 2.5 at $n = 192$), because the error term is a mean over suppliers while the penalty is not scaled. **Scaling λ with** $1/n$ — a prior of constant strength, anchored at $\lambda = 0.05$ for 32 labels — removes this bias (0.76 vs. 0.78 at $n = 192$), beats the defaults in every seed from eight labels upwards, and under the default acceptance rule caused no harmful acceptance at any size. Choosing λ by cross-validation was tested and not adopted: the one-standard-error rule [9] over-regularises in the middle range (10.6 vs. 5.9 at 32 labels), the minimum-error rule is too noisy with few labels (24.5 vs. 18.4 at eight), and both cost an order of magnitude more computation. The scaling constant was itself set on the same synthetic data; it

Table 5. In-sample versus 5 % cross-validated acceptance on the E2 runs (30 seeds; error against true scores; defaults 29.7). Harm: share of runs in which the weights in use are worse than the defaults. *Synthetic data.*

n	λ	accepted in-s. / CV	error in use in-s. / CV	harm in-s. / CV
8	0	100 / 23 %	37.7 / 30.8	50 / 7 %
8	0.05	100 / 57 %	16.7 / 20.8	10 / 3 %
12	0	100 / 47 %	25.7 / 27.7	37 / 20 %
12	0.05	100 / 70 %	12.1 / 16.3	7 / 3 %
16	0.05	100 / 87 %	9.9 / 11.8	0 / 0 %
≥ 24	0.05	100 / 100 %	identical	0 / 0 %

is a reasoned default.

7.5 Stability of the recovered weights (E3)

Across 100 portfolios of 32 labels ($\lambda = 0.05$), the mean L1 distance to the hidden weighting is 0.170, against 0.345 for the defaults (Figure 5). Large deviations are recovered reliably: business impact (14 % → 22 %, calibrated mean 19.5 %), sourcing strategy (8.75 % → 16 %, 14.1 %) and ESG rating (12 % → 3 %, 6.3 %) move in the right direction in all 100 seeds. Small deviations are not: for two factors whose default and hidden weights differ by half a percentage point, the direction is right in only 67 and 54 seeds, close to chance. Estimates are shrunk towards the default as intended; large shifts are recovered at roughly two-thirds of their size.

7.6 Acceptance rules: in-sample versus cross-validated

The demonstrator originally accepted calibrated weights if they reduced the *in-sample* error by at least 5 %. In E1–E3 this rule accepted practically every calibration, including the eight-label, unregularised runs in which the weights were worse than the defaults in half of the seeds. **An in-sample rule is not a safeguard against overfitting**; it only protects against calibrations that change nothing. It was replaced by an out-of-sample test: refit on $k - 1$ folds, evaluate on the held-out fold, repeat with reshuffled folds (5×3, deterministic), and require the pooled out-of-fold error to improve by at least 5 %. Table 5 reports this 5 % rule (commit `ddcb977`); Section 7.8 adds the second condition that is now the default.

The cross-validated rule sharply reduces harm where harm occurs (50 % to 7 % at eight unregularised labels). It is conservative: with few labels it also rejects helpful calibrations, so the error of the weights in use is higher than under the in-sample rule (20.8 vs. 16.7 at $n = 8$), though still well below the defaults. It trades expected gain for a lower risk of making things worse — the appropriate trade-off for weights that drive supplier decisions. From about 24 labels both rules agree. On the shipped data, the rule changes one visible outcome: a calibration restricted to the ten labelled "plastics" suppliers looked excellent in-sample (36.8 → 10.4) but was worse out of sample (36.8 → 41.7) and is now rejected. Group-specific calibration needs enough labels per group.

7.7 When experts do not judge like the model (E4)

E1–E3 generate labels from the linear model family that calibration fits: the best case. E4 replaces that policy with alternatives a real panel might follow: more or less noise, coarser rounding, a uniform level shift (10 points stricter), an interaction between business impact and single sourcing, a knock-out floor (a severe compliance or insolvency rating lifts the judgement to at least 70), a non-compensatory "worst factor dominates" policy, and two experts with different weightings. For each policy, an **approximation floor** — the error of the best constrained linear weighting on 2,000 noise-free judgements — measures how far it lies outside what weights can express. Calibration then runs with production settings on 16, 32 and 64 labels, 30 seeds each (Table 6, Figure 6).

Noise and rounding cost labels, not validity: with linear experts, calibration stays effective under coarse rounding and doubled noise, but needs more labels. **Non-linear policies leave a floor no weighting removes**: for the interaction, knock-out and worst-factor policies, calibration closes much of the gap above the floor with 32–64 labels, but class agreement barely improves. Weights cannot learn a policy that is not additive, and a large remaining error should be reported as exactly that signal. **Knock-outs belong in escalation rules, not in weights**: with sixteen labels and a fixed λ, calibration is worse than the defaults on average, and even the 5 % rule lets 10–13 % of runs end with harmful weights (0–3 % under the current default, mostly because such calibrations are no longer accepted). The demonstrator's escalation rules are the right mechanism; knock-outs should be *elicited* from category managers and encoded as rules. **A level offset cannot be expressed by weights**, which sum to one. Calibration then distorts the weights to imitate the offset: weight moves towards factors that are usually rated high (the shift correlates at 0.89 with the factor's mean rating), and insolvency signals and compliance status — the rare, severe drivers a risk model should protect most — are pushed to the minimum. The demonstrator now diagnoses this: it flags a mean difference of at least 5 points that is also two standard errors from zero and withholds such calibrations for review. The flag caught every level-shift and worst-factor run, 30–37 % of knock-out runs, at most 7 % of purely linear runs at sixteen labels and none from 32. **Disagreeing experts are the hardest case**: their disagreement acts as structured label noise, and the 5 % rule accepted harmful weights in 43 % of runs at sixteen labels — the motivation for E5.

Fit diagnostics. Since knock-outs and non-additive judgement cannot be fixed by weights, the report says when they are likely, without blocking approval. A *high residual* (cross-validated error at

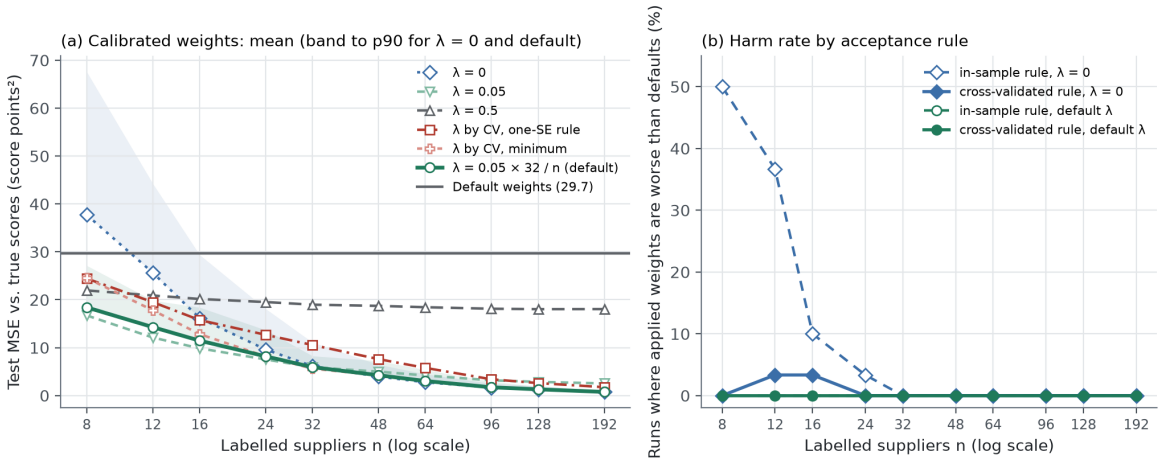


Figure 4. (a) Test error of calibrated weights against noise-free true scores, by number of labels, for fixed λ, the scaled default and λ chosen by cross-validation (mean over 30 seeds; band to the 90th percentile). (b) Share of runs in which the weights actually applied are worse than the defaults, under the in-sample rule and the default cross-validated rule (5 % and $z \geq 2$). *Synthetic data.*

Table 6. E4: calibration under misspecified expert policies. Errors in points^2 against the policy's noise-free judgement, "calibrated" at $n = 32$. Excess removed: share of the default weights' error above the linear floor that calibration removes, at $n = 16/32/64$. Harm: share of runs with weights in use worse than the defaults, at $n = 16/32$. Original: fixed $\lambda = 0.05$ and the 5 % rule; current: scaled λ and the rule with $z \geq 2$. *Synthetic data.*

Policy	floor	default	calibrated	excess removed		harm		class agreement
				original	current	original	current	default → cal.
linear (reference)	0	29.7	5.7	69 / 81 / 87 %	62 / 81 / 91 %	0 / 0 %	0 / 0 %	79 → 91 %
linear, $\sigma = 8$	0	29.7	11.7	30 / 61 / 75 %	39 / 61 / 76 %	7 / 0 %	0 / 0 %	79 → 87 %
linear, steps of 10	0	29.7	7.0	63 / 76 / 84 %	58 / 76 / 88 %	0 / 0 %	0 / 0 %	79 → 90 %
level shift +10	62.3	157.4	77.6	74 / 84 / 90 %	77 / 84 / 91 %	0 / 0 %	0 / 0 %	44 → 60 %
interaction	71.9	103.1	88.0	9 / 48 / 68 %	24 / 48 / 66 %	10 / 0 %	0 / 0 %	63 → 65 %
knock-out floor	98.3	127.0	118.8	−24 / 28 / 62 %	8 / 28 / 58 %	10 / 13 %	0 / 3 %	66 → 69 %
worst factor dominates	284.3	418.0	328.1	57 / 67 / 82 %	69 / 67 / 78 %	0 / 0 %	0 / 0 %	12 → 27 %
two experts disagree	0	5.3	5.3	−84 / 1 / 42 %	−22 / 1 / 29 %	43 / 23 %	0 / 0 %	90 → 91 %

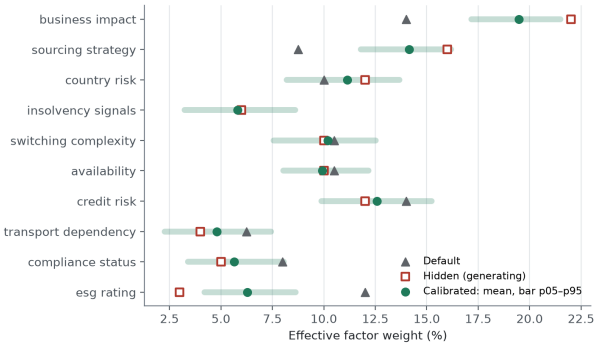


Figure 5. Effective factor weights: configured default, hidden weighting, and calibrated weights (mean and 5th–95th percentile over 100 portfolios of 32 labels, $\lambda = 0.05$). *Synthetic data.*

least 40 % of the label variance) detects 63–100 % of non-linear runs and 0–7 % of linear ones. A *knock-out candidate* (at least three suppliers with a severe rating judged at least 5 points and two standard errors riskier than the model predicts, after removing the offset) found the knock-out policy in 13/53/97 % of runs at $n = 16/32/64$, always on the right factor family, with at most 3 % false hints from linear experts. A factor *pushed to the minimum weight* is reported only as "check this factor": it is unspecific. None of the hints detects expert disagreement reliably. E4 thus maps where calibration works (noisy but broadly additive judgement), where it is partial (non-additive policies) and where it fails (knock-outs, level offsets, disagreement) — but it cannot say which policy real category managers follow.

7.8 Requiring a clear improvement (E5)

A fixed 5 % threshold cannot tell a real improvement from a lucky one when the estimate itself is noisy. The acceptance rule therefore has a second condition. Cross-validation yields an out-of-fold error for every labelled supplier under the active weights and under refitted weights; from the per-supplier differences the rule computes the mean improvement and its standard error, whose ratio z must reach a threshold. This standard error is optimistic, because out-of-fold errors are not independent [20, 2]; z is a screening statistic, not a test with a nominal error rate, and the threshold

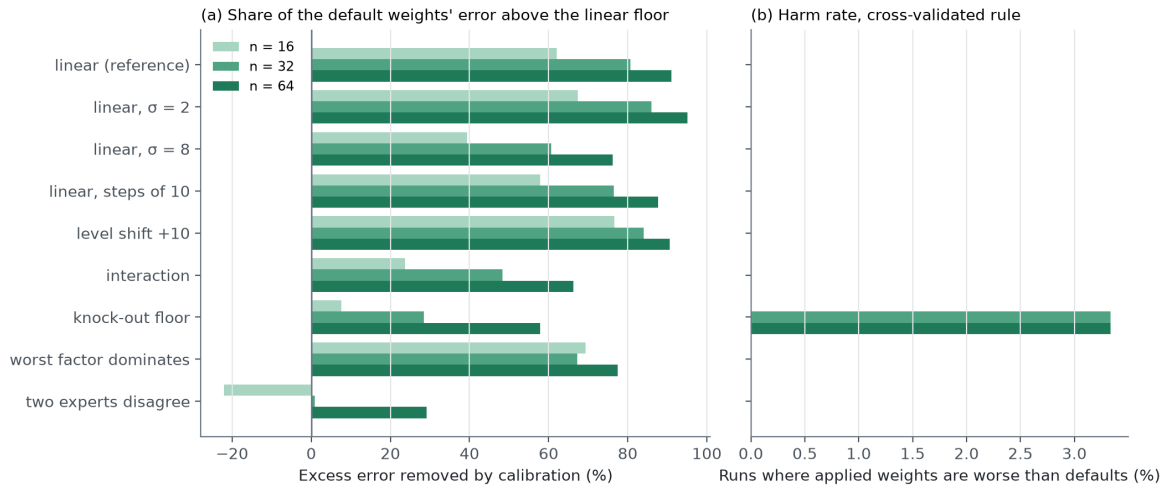


Figure 6. (a) Share of the default weights' excess error above the linear floor that calibration removes, by expert policy and number of labels. (b) Share of runs in which the weights in use are worse than the defaults under the default rule (5 % and $z \geq 2$); almost all bars are zero. *Synthetic data.*

Table 7. E5: effect of the uncertainty threshold, averaged over 20 scenarios (100 seeds each). Missed gain: error of the weights in use minus the better of default and calibrated weights, as a share of the default error. Rel. error: error of the weights in use divided by the default error. *Synthetic data.*

$z \geq$	harm mean / worst	accepted	missed gain	rel. error
0 (5 %)	7.4 / 30 %	61 %	10.1 %	0.78
1	4.2 / 17 %	46 %	12.4 %	0.80
1.5	2.2 / 8 %	34 %	15.2 %	0.83
2 (default)	**1.1 / 4 %**	24 %	18.7 %	0.87
2.5	0.4 / 3 %	15 %	22.2 %	0.90
3	0.1 / 1 %	10 %	25.1 %	0.93

was chosen **empirically**. E5 covers 20 scenarios (five expert policies × 8/16/32/64 labels), seven thresholds and 100 seeds each, with the scaled λ (Table 7).

The selection criterion was the *smallest threshold for which no scenario exceeds 5 % harmful acceptances*: $z \geq 2$. Against the 5 % rule alone, it gives up about nine percentage points of the default error in expected improvement (0.78 → 0.87) for a worst-case harm rate that falls from 30 % to 4 %. Re-run with the new default, harm falls to zero for disagreeing experts (from 43/23 % at 16/32 labels), to 0/3 % for knock-outs, and to 0 % at every size in E2 with the scaled λ; the reference portfolio is still accepted ($z = 2.4$). **Calibration now has to be earned**: with linear experts, 17 % of calibrations are applied at 8 labels, 50 % at 16 and 87 % at 32; with disagreeing experts, none at 16 or 32. When it withholds a calibration, the rule keeps the defaults and states why. For practice this means roughly **30 or more consistent labels per calibration scope**, and measuring expert agreement before calibrating a scope with several labelling experts. A rule that sometimes forgoes an improvement is the right failure mode for weights that drive supplier decisions; a rule that sometimes makes them worse is not. The threshold was selected and evaluated on the same synthetic scenarios and should be treated as a reasoned default.

7.9 What the demonstration shows, and what it does not

Under controlled conditions, the procedure generalises close to the noise floor, recovers the direction and roughly the size of substantial weight differences, needs regularisation when labels are few, and shows the user in-sample figures that are optimistic by a quantifiable margin. It does not show how real expert judgement behaves: E1–E3 use best-case labels, and E4 cannot say which policy describes real category managers or whether it changes over time. Policy-capturing research suggests that linear models often describe holistic judgements well [15]; whether this holds for supplier-risk judgements is an empirical question. The demonstration also says nothing about **predictive validity**.

8 Comparison and discussion

8.1 What the benchmark and the demonstrator show together

The benchmark locates a gap rather than a winner. Spreadsheets keep the method in the procurement team's hands but cannot hold it to account; platforms bring data, scale and operational maturity but keep the method partly or largely outside the customer's view; open-source agent projects offer architecture without method. No approach is strong both on *data coverage* and on *ownership of the method*, and none of the established ones evaluates risk and performance on one basis. The demonstrator shows that the method layer can be built lean and can carry both views: deterministic and tested, orchestrated by specialised agents over a shared state, governed by a real

Table 8. A layered reading of supplier risk evaluation.

Layer	Question	Strong here / suggested provider
Signal	What is happening to this supplier, its country, its tier-N network, now?	Platforms (signals, coverage); subscription or open data (governance indicators, sanction lists, insolvency registers)
Method	How do signals and internal knowledge become a class, with which weights, and why?	Lean Agentic (transparency, calibration, group weights); in-house, owned by procurement
Decision	What do we do about it, and who decides?	Shared; category managers and a named decision owner, see Section 9

pause and versioned approvals, able to learn under a cross-validated acceptance test, with risk management, performance evaluation and an action framework from one catalogue — in a small, MIT-licensed code base. What neither part shows is that real category managers judge in a way a linear model can capture, that calibrated scores predict disruptions, or that the approach scales operationally to an enterprise portfolio.

8.2 The hybrid reading: signals from outside, method in-house

The most useful reading of Figure 1 is not "which approach is best" but "which layer each approach should provide" (Table 8). In this reading the demonstrator does not compete with a platform; it *consumes* one. The integration points exist: rating sources turn any indicator, including a platform score, an alert count or a country index, into a 1–5 rating; a pluggable data source delivers indicators; and data providers fill missing indicators with recorded origin — the political stability provider is a small instance of a signal layer built on open data. Three consequences follow. *Platform scores become inputs, not verdicts*: procurement decides, and calibrates, how much they count per material group, and the class remains recomputable. *Double counting must be managed*: a platform score that already contains country risk overlaps with a separate country factor; either one is dropped or calibration is left to down-weight it, which works only with enough labels. *Licence terms matter*: whether platform scores may be stored, versioned and recomputed in-house depends on the contract, which this paper did not examine.

8.3 When which approach fits

Because the profiles are not ranked, the choice depends on the situation. A *spreadsheet with discipline* — written definitions, versioned weights, a fixed review date — is adequate for a small portfolio with stable risk drivers and no documentation duty. A *commercial platform* is hard to replace where tier-N exposure, real-time monitoring or regulatory evidence dominate; building that coverage in-house is neither lean nor realistic. A *Lean Agentic method layer* fits organisations that have outgrown the spreadsheet, want to own and justify their method, need material-group weighting and want their category managers' judgement to shape the model — also alongside a platform. For a mid-sized procurement organisation, the most likely configuration is the combination.

8.4 The cost of being lean

"Lean" and "open source" do not mean free. Cost shifts from licences to ownership (someone maintains configuration, code and data connections), skills (a configuration file to change the method, Python to extend the system) and responsibility (no vendor, no service levels, no security hardening; operational maturity is rated 2). The approach is lean in what it *builds*, not necessarily in what it *requires* to run.

8.5 What the "agentic" part contributes

Scoring, calibration and recommendations use no language model at all. For the current scope, the agent architecture is not strictly necessary; the same logic could run as a pipeline. It pays off as the system grows: the supervisor routes bounded loops explicitly, foreseeable additions (an external-signal agent, a document-extraction agent, an explanation agent) become new nodes rather than rewrites, and checkpointing provides the pause-and-resume that human review needs. The value of "agentic" here is **orchestration and extensibility, not autonomy**: authority over scores and decisions stays with code that can be recomputed and with people who can be named.

9 Governance and decision ownership

A risk score does not decide anything; it informs a decision made by someone accountable for it. Table 9 proposes how roles could be assigned; the demonstrator does not enforce them.

Two principles follow. **The method owner sets the floor**: escalation rules express non-negotiable positions and are not subject to calibration, which optimises agreement with average judgement, while floors exist precisely for the cases averages hide. **Calibration proposes, people decide**: for weights that drive supplier decisions, the recommended setting is to propose rather than auto-apply, with the approver seeing the number of labels, the cross-validated and in-sample error, and old and new weights. **Separation of duties**: the people whose labels drive a calibration should not be the only ones to approve it, or a team could steer the weights by the way it labels; the demonstrator records approvers but has no role model to enforce this.

Table 9. Proposed ownership of the elements of the method.

Element	Owner (proposed)	Changed how	Recorded where
Criteria, scales, default weights, thresholds, escalation rules	Method owner (e.g. procurement excellence)	Reviewed configuration change, new model version	Version control; model version on every result
Expert ratings per supplier	Category manager	During the supplier review	Supplier record; rating provenance per factor
Holistic labels for calibration	Category managers, blind to the model score	Periodic labelling round	Supplier record
Calibrated weights	Approver distinct from the label providers	Approval at the review pause	Versioned weight store with approver, metrics, timestamp
Manual class overrides	Decision owner for the supplier	Review decision with mandatory comment	Assessment; audit trail
Indicators from external sources	Data owner per source	Data refresh	Provider and data vintage per indicator; source data not versioned

A calibration cycle in the supplier review. (1) Category managers record a holistic score for the suppliers they know well, *before* seeing the model score, to avoid anchoring. (2) The portfolio is scored and calibrated per scope, accepted or rejected on cross-validated error. (3) The approver reviews proposed weights and flagged suppliers; approved weights become a new version, and a snapshot records the result. (4) Weight changes and the class changes they cause are communicated, since a weight change that moves suppliers between classes is itself a decision. (5) In the next cycle the regularisation still anchors on the method owner's defaults, so repeated calibration does not drift.

Risks to governance. *Label gaming* — mitigated by blind labelling, separation of duties, reporting how much each weight moved, and the minimum weight, which prevents criteria from being calibrated away. *Label drift* — versioned weights and the assessment history make it visible; they do not prevent it. *Automation bias* — the completeness flag and the stated number of labels are partial counter- measures; the class, not the decimal score, should be the unit of communication. *Accountability gaps* — for due-diligence documentation the record must show who decided, on what basis, and what was done; the audit trail provides the basis, the decision owner remains responsible.

10 Limitations

Evidence. No field data supports the demonstration; all suppliers and labels are synthetic and labelled as such. E1–E3 use labels from the fitted model family, the best case; E4 tests constructed alternatives and shows clear failure modes, but cannot establish which policy real experts follow. Agreement with expert judgement is not predictive validity. The literature was read at abstract level, and claims drawn from it are phrased accordingly.

Benchmark. The success factors and all ratings come from the authors of one of the rated approaches; rationales, confidence marks and the v0.2 correction reduce this bias but do not remove it. The v0.3 review added a factor on which the proposed approach is strong (risk and performance integration), sharpened another towards agentic orchestration, and re-rated five factors in its favour after practitioner feedback; these changes are documented, but they increase the need for independent re-rating. The platforms were rated on public information as of October 2026 — whether they offer performance evaluation or agentic workflows beyond their public documentation is not known — and the spreadsheet profile is a stereotype, not a survey.

Method. The default acceptance rule ($z \geq 2$) is conservative — it withholds half or more of all calibrations with 16 or fewer labels — and its threshold was chosen and evaluated on the same scenarios, with a standard error that ignores the dependence between folds. The in-sample rule remains available and should not be used for real decisions. Knockouts, level offsets and non-additive policies cannot be learned by weights; offsets are withheld for review, the other hints were tuned on constructed policies, and disagreement between experts is not reliably detected. The λ scaling constant was set on synthetic data. The criteria, weights and thresholds are illustrative, including the bands for political stability and time to exit and the factor-level actions; none was calibrated or validated. The performance view uses the same engine but is covered by none of the experiments, and its calibration is switched off in the template.

Demonstrator. It is not production-hardened: no roles or permissions, review pauses held in memory only, no live external signal feeds (the provider interface reads open data and exports, the bundled political stability table is fictional, and API integrations

are placeholders), an assessment history in local files without access control, and no tracking of actions to closure.

11 Future work

Method. Validate the λ default on field data, possibly per material group. Turn diagnostics into proposals — a draft escalation rule for a knock-out candidate, a threshold shift for a level offset — reviewed like calibrated weights. Found the acceptance test better, with variance estimators that account for fold dependence [20] and validation on field data. Measure expert disagreement with repeated labels and calibrate only where agreement is adequate. Report bootstrap intervals for calibrated weights; Figure 5 shows that small shifts are not well supported. Allow ordinal labels, and partial pooling across material groups so that small groups borrow strength from the global fit.

Evidence. A field pilot in one or two material groups, with labels collected blind to the model score and a pre-registered comparison of cross-validated error with and without calibration. An independent re-rating of the benchmark by three to five practitioners, shown as bands in Figure 1, in particular of the v0.3 additions and v0.4 consolidation, including integration (now factor 15); ideally including hands-on evaluation of the platforms. Predictive validation, linking scores to observed incidents over time — the only route to the question this paper leaves open.

System. *External data sources behind the provider interface*: the World Bank governance indicators retrieved online instead of from a downloaded table, an ESG rating platform for ESG scores and questionnaire status, an ERP system for on-time delivery and quality, and a credit agency for credit scores and insolvency signals, each recording the data vintage so that results stay recomputable. *An external-signal agent* on open data (sanction lists, insolvency announcements, event monitoring) as time-varying indicators. *Further views and a joint reading*: the view mechanism is not limited to two; a sustainability view or a view for strategic suppliers needs only a configuration on the shared catalogue, and two extensions are open — a joint portfolio reading of performance grade against risk class, and calibration of the performance view against its own labels with the same safeguards. *An explanation agent* that writes a narrative from locked numbers. *Roles and persistence*: enforced separation of duties, a persistent checkpointer, a central history store and tracking of actions to closure. *A platform integration pattern* that turns a platform score into a rating source and handles overlapping factors.

Benchmark maintenance. Repeat the public-information review of the platforms periodically with dated ratings, and add vendors whose methodology is publicly documented.

12 Conclusion

Supplier risk evaluation in mid-sized organisations sits between a spreadsheet the team owns but cannot hold to account and a platform that brings data and scale but whose method the team does not fully own; open-source agent projects offer architecture but rarely a method. Across all three, the weights that turn criteria into a score are usually set once and never tested against the judgement of the people who know the suppliers.

This paper proposed fifteen success factors and used them to profile four approaches without ranking them. The comparison locates a gap rather than a winner: no approach combines data coverage with ownership of the method, and the established ones leave risk management and performance evaluation in separate systems. Lean Agentic AI addresses the method side and closes the second gap: evaluate risk and performance as two views on one catalogue, start from existing scorecard practice, run the method as an agentic workflow of specialised agents over a shared state, keep every number deterministic, calibrate weights against expert labels under constraints with a cross-validated acceptance test, map results to concrete actions, and pause for human approval wherever judgement is required. On synthetic data, calibration generalises close to the noise floor and recovers substantial weight differences; with few labels it needs both regularisation and an out-of-sample acceptance test, and the validation found and fixed a rule that would otherwise have let harmful calibrations through.

What remains open is stated as plainly: the labels were synthetic, agreement with experts is not predictive validity, and the approach supplies external signals only in part. The most realistic deployment is therefore hybrid: signals from a platform or open data, and one method for risk and performance that is transparent, versioned, calibrated and owned by the procurement team that is accountable for it.

References

[1] Aiman-Smith, L.; Scullen, S. E.; Barr, S. H. Conducting studies of decision making in organizational contexts: a tutorial for policy-capturing and other regression-based techniques. *Organizational Research Methods* 5(4), 388–414, 2002. doi:10.1177/109442802237117

[2] Bengio, Y.; Grandvalet, Y. No unbiased estimator of the variance of K-fold cross-validation. *Journal of Machine Learning Research* 5, 1089–1105, 2004.

[3] Borcherding, K.; Eppel, T.; von Winterfeldt, D. Comparison of weighting judgments in multiattribute utility measurement. *Management Science* 37(12), 1603–1619, 1991. doi:10.1287/mnsc.37.12.1603

[4] Chai, J.; Liu, J. N. K.; Ngai, E. W. T. Application of decision-making techniques in supplier selection: a systematic review of literature. *Expert Systems with Applications* 40(10), 3872–3885, 2013. doi:10.1016/j.eswa.2012.12.040

[5] Dawes, R. M. The robust beauty of improper linear models in decision making. *American Psychologist* 34(7), 571–582, 1979. doi:10.1037/0003-066X.34.7.571

[6] Fan, Y.; Stevenson, M. A review of supply chain risk management: definition, theory, and research agenda. *International Journal of Physical Distribution & Logistics Management* 48(3), 205–230, 2018. doi:10.1108/IJPDLM-01-2017-0043

[7] Goldberg, L. R. Man versus model of man: a rationale, plus some evidence, for a method of improving on clinical inferences. *Psychological Bulletin* 73(6), 422–432, 1970. doi:10.1037/h0029230

[8] Hammond, K. R. Probabilistic functioning and the clinical method. *Psychological Review* 62(4), 255–262, 1955. doi:10.1037/h0046845

[9] Hastie, T.; Tibshirani, R.; Friedman, J. *The Elements of Statistical Learning*, 2nd ed. Springer, 2009. doi:10.1007/978-0-387-84858-7

[10] Ho, W.; Xu, X.; Dey, P. K. Multi-criteria decision making approaches for supplier evaluation and selection: a literature review. *European Journal of Operational Research* 202(1), 16–24, 2010. doi:10.1016/j.ejor.2009.05.009

[11] Ho, W.; Zheng, T.; Yildiz, H.; Talluri, S. Supply chain risk management: a literature review. *International Journal of Production Research* 53(16), 5031–5069, 2015. doi:10.1080/00207543.2015.1030467

[12] Hoerl, A. E.; Kennard, R. W. Ridge regression: biased estimation for nonorthogonal problems. *Technometrics* 12(1), 55–67, 1970. doi:10.1080/00401706.1970.10488634

[13] Jacquet-Lagrèze, E.; Siskos, J. Assessing a set of additive utility functions for multicriteria decision-making, the UTA method. *European Journal of Operational Research* 10(2), 151–164, 1982. doi:10.1016/0377-2217(82)90155-2

[14] Jacquet-Lagrèze, E.; Siskos, Y. Preference disaggregation: 20 years of MCDA experience. *European Journal of Operational Research* 130(2), 233–245, 2001. doi:10.1016/S0377-2217(00)00035-7

[15] Karelaia, N.; Hogarth, R. M. Determinants of linear judgment: a meta-analysis of lens model studies. *Psychological Bulletin* 134(3), 404–426, 2008. doi:10.1037/0033-2909.134.3.404

[16] Karren, R. J.; Barringer, M. W. A review and analysis of the policy-capturing methodology in organizational research. *Organizational Research Methods* 5(4), 337–361, 2002. doi:10.1177/109442802237115

[17] Kaufmann, D.; Kraay, A.; Mastruzzi, M. The Worldwide Governance Indicators: methodology and analytical issues. *Hague Journal on the Rule of Law* 3(2), 220–246, 2011. doi:10.1017/S1876404511200046

[18] Kohavi, R. A study of cross-validation and bootstrap for accuracy estimation and model selection. In *Proceedings of the 14th International Joint Conference on Artificial Intelligence (IJCAI)*, vol. 2, 1137–1143, 1995.

[19] Lawson, C. L.; Hanson, R. J. *Solving Least Squares Problems*. Classics in Applied Mathematics 15, SIAM, 1995 (reprint of 1974). doi:10.1137/1.9781611971217

[20] Nadeau, C.; Bengio, Y. Inference for the generalization error. *Machine Learning* 52(3), 239–281, 2003. doi:10.1023/A:1024068626366

[21] Ouyang, S.; Zhang, J. M.; Harman, M.; Wang, M. An empirical study of the non-determinism of ChatGPT in code generation. *ACM Transactions on Software Engineering and Methodology* 34(2), 1–28, 2025. doi:10.1145/3697010

[22] Pöyhönen, M.; Hämäläinen, R. P. On the convergence of multiattribute weighting methods. *European Journal of Operational Research* 129(3), 569–585, 2001. doi:10.1016/S0377-2217(99)00467-1

[23] Stone, M. Cross-validatory choice and assessment of statistical predictions. *Journal of the Royal Statistical Society: Series B* 36(2), 111–133, 1974. doi:10.1111/j.2517-6161.1974.tb00994.x

[24] Tang, C. S. Perspectives in supply chain risk management. *International Journal of Production Economics* 103(2), 451–488, 2006. doi:10.1016/j.ijpe.2005.12.006

[25] Weber, M.; Borcherding, K. Behavioral influences on weight judgments in multiattribute decision making. *European Journal of Operational Research* 67(1), 1–12, 1993. doi:10.1016/0377-2217(93)90318-H

[26] Zsidisin, G. A.; Ellram, L. M.; Carter, J. R.; Cavinato, J. L. An analysis of supply risk assessment techniques. *International Journal of Physical Distribution & Logistics Management* 34(5), 397–413, 2004. doi:10.1108/09600030410545445

Software, vendor and web sources. [CODE] source code reviewed; [DOC] documentation read; [WEB] web page read. Open-source repositories: aniket-work, *supply-chain-risk-intelligence* [CODE]; Bhardwaj-Saurabh, *OmniSupply-AI* [CODE]; chinmaynadgir, *supplychain-ai-agent* [CODE]; poshalanavateja, *Vendor-Bid-Evaluation-Ai* [CODE]; mergisi, *awesome-openclaw-agents*, agent `vendor-evaluator` [CODE] (all GitHub). Prewave, "How is the Prewave Score generated?", help.prewave.com [DOC], and prewave.com [WEB]. Sphera, *Supply Chain Risk Management*, sphera.com [WEB], and white paper on the German supply-chain due-diligence act, 2023 [WEB]. LangGraph documentation: state graphs, interrupts, checkpointers [DOC]. Academic sources were checked against Crossref or OpenAlex metadata and read at abstract level unless noted.

Appendix A: Full comparison matrix

Table 10. Ratings per success factor and approach on the scale 1–5, with confidence (H, M, L). For SaaS, the mean of Prewave and Sphera, with both values in brackets where they differ. Generated from `research/comparison-matrix.yaml`; the rationale for every cell is in `research/comparison-matrix.md`.

#	Success factor	Excel	SaaS	OSS	Lean
1	Structured criteria & weights (objective + subjective)	3 M	4 M	2 H	4 H
2	Traceability & reproducibility	2 M	2.5 (3/2) L	2 H	4 H
3	Methodological transparency	4 M	2.5 (3/2) M	3 H	5 H
4	Expert calibration / ability to learn	1 M	2 L	1 H	4 H
5	Action framework	2 M	4 M	2 H	3.5 H
6	Human-in-the-loop & governance	2 M	4 M	2 H	3.5 H
7	External signals & data coverage	1 H	5 M	2 H	2.5 M
8	Regulatory evidence (due-diligence documentation)	2 M	4.5 (5/4) M	1 H	2 H
9	Cost / total cost of ownership	3 M	2 M	4 M	4 M
10	Time-to-value / ease of adoption	3 M	3 L	2 H	4 M
11	Customisability & data sovereignty	4 M	2 M	3 H	5 H
12	Scalability	2 M	5 M	2 H	3 L
13	Agentic orchestration & extensibility	1 H	2.5 (3/2) M	4 H	4 H
14	Operational maturity & support	3 M	5 M	1 H	2 H
15	Integration of risk management and performance evaluation	2 M	2 L	2 H	4 H

Data and reproducibility. All data is synthetic or fictional; code, experiment scripts, result tables and figure generators are in the project repository (MIT licence). © 2026 Csaba Bakay.